

Unit 5: Transport and Application Layer Security

Unit 5: Transport and Application Layer Security

Web Security Issues

- **Introduction:**

Web security issues primarily relate to securing communication and data exchanged over the Internet. These issues can be categorized into two main layers of security: Transport Layer Security (TLS/SSL) and Application Layer Security.

Unit 5: Transport and Application Layer Security

Web Security Issues

- **Transport Layer Security(TLS/SSL):**

TLS/SSL is primarily responsible for securing the communication between the client and the web server. It provides data encryption, authentication, and integrity checks. Common web security issues related to TLS/SSL include:

1. **Inadequate Encryption**
2. **Certificate Issues**
3. **Vulnerabilities in Protocols**
4. **Man-in-the-Middle (MITM) Attacks**
5. **Insecure Cipher Suites**
6. **Mixed Content**

Unit 5: Transport and Application Layer Security

Web Security Issues

- 1. Inadequate Encryption:** The use of weak or outdated encryption algorithms can lead to data interception and unauthorized access.
- 2. Certificate Issues:** Expired, self-signed, or misconfigured SSL/TLS certificates can result in trust issues, leading to potential security risks.
- 3. Vulnerabilities in Protocols:** Vulnerabilities in specific TLS/SSL protocols, such as the infamous Heartbleed bug in OpenSSL, can compromise security.

Unit 5: Transport and Application Layer Security

Web Security Issues

- 4. Man-in-the-Middle (MITM) Attacks:** MITM attacks can occur when an attacker intercepts the encrypted communication between a client and a server, leading to data exposure.
- 5. Insecure Cipher Suites:** Weak or deprecated cipher suites can be exploited by attackers to decrypt encrypted data.
- 6. Mixed Content:** Combining secure (HTTPS) and non-secure (HTTP) content on a web page can expose users to potential security threats.

Unit 5: Transport and Application Layer Security

Web Security Issues

- **Application Layer Security:**

Application layer security involves securing the web application itself, including the web server, databases, and the application code. Common web security issues at the application layer include:

1. **Injection Attacks**
2. **Cross-Site Request Forgery (CSRF)**
3. **Cross-Origin Resource Sharing (CORS) Misconfiguration**
4. **Inadequate Access Control**

Unit 5: Transport and Application Layer Security

Web Security Issues

- **Application Layer Security:**
 5. Insecure Session Management
 6. Security Misconfigurations
 7. Lack of Input Validation
 8. Inadequate Authentication and Authorization

Unit 5: Transport and Application Layer Security

Web Security Issues

- 1. Injection Attacks:** SQL injection, Cross-Site Scripting (XSS), and other injection attacks can compromise the application's security and data integrity.
- 2. Cross-Site Request Forgery (CSRF):** CSRF attacks can manipulate a user's interaction with a web application, leading to unauthorized actions.

Unit 5: Transport and Application Layer Security

Web Security Issues

- 3. Cross-Origin Resource Sharing (CORS) Misconfiguration:** Poorly configured CORS settings can enable unauthorized domains to make requests, leading to security breaches.
- 4. Inadequate Access Control:** Poor access control mechanisms can result in unauthorized users gaining access to sensitive data or functions.

Unit 5: Transport and Application Layer Security

Web Security Issues

- 5. Insecure Session Management:** Weak session management can expose user sessions to attacks, allowing unauthorized access.
- 6. Security Misconfigurations:** Misconfigured web servers, databases, or application code can lead to vulnerabilities that attackers may exploit.

Unit 5: Transport and Application Layer Security

Web Security Issues

- 7. Lack of Input Validation:** Not properly validating and sanitizing user inputs can expose applications to injection attacks.
- 8. Inadequate Authentication and Authorization:** Weak or missing authentication and authorization mechanisms can lead to unauthorized access.

Unit 5: Transport and Application Layer Security

TLS & SSL Security

TLS (Transport Layer Security) and SSL (Secure Sockets Layer) are essential for securing web communication at the transport layer. While they primarily address encryption, authentication, and data integrity, they can also contribute to mitigating some application layer security issues. Here's how they can help overcome web security issues:

Unit 5: Transport and Application Layer Security

TLS & SSL Security

- 1. Inadequate Encryption:** TLS/SSL provide strong encryption to protect data in transit. Ensure that the latest, secure encryption protocols and cipher suites are configured on the web server.
- 2. Certificate Problems:** Properly manage SSL/TLS certificates. Regularly renew certificates before they expire, use trusted certificate authorities, and validate the certificate chain.

Unit 5: Transport and Application Layer Security

TLS & SSL Security

- 3. Protocol Vulnerabilities:** Keep TLS/SSL protocols and libraries up-to-date to address vulnerabilities. Disable outdated or insecure protocols (e.g., SSLv2 and SSLv3).
- 4. Man-in-the-Middle (MITM) Attacks:** TLS/SSL helps prevent MITM attacks by encrypting communication. Implement strong certificate validation to ensure the server's authenticity. Use HTTP Strict Transport Security (HSTS) to enforce secure connections.

Unit 5: Transport and Application Layer Security

TLS & SSL Security

- 5. Insecure Cipher Suites:** Carefully select and configure secure cipher suites for your TLS/SSL setup. Remove any deprecated or weak ciphers from your configuration.
- 6. Mixed Content:** Enable HTTPS across the entire website to prevent mixed content issues. Utilize content security policies (CSP) to enforce secure content loading.

Unit 5: Transport and Application Layer Security

TLS & SSL Security

- However, TLS/SSL alone may not fully address application layer security issues. To overcome application layer problems, consider these additional measures:
1. **Injection Attacks:** Implement input validation and parameterized queries to prevent SQL injection and XSS attacks.
 2. **Cross-Site Request Forgery (CSRF):** Use anti-CSRF tokens and ensure that sensitive actions require user authentication and authorization.

Unit 5: Transport and Application Layer Security

TLS & SSL Security

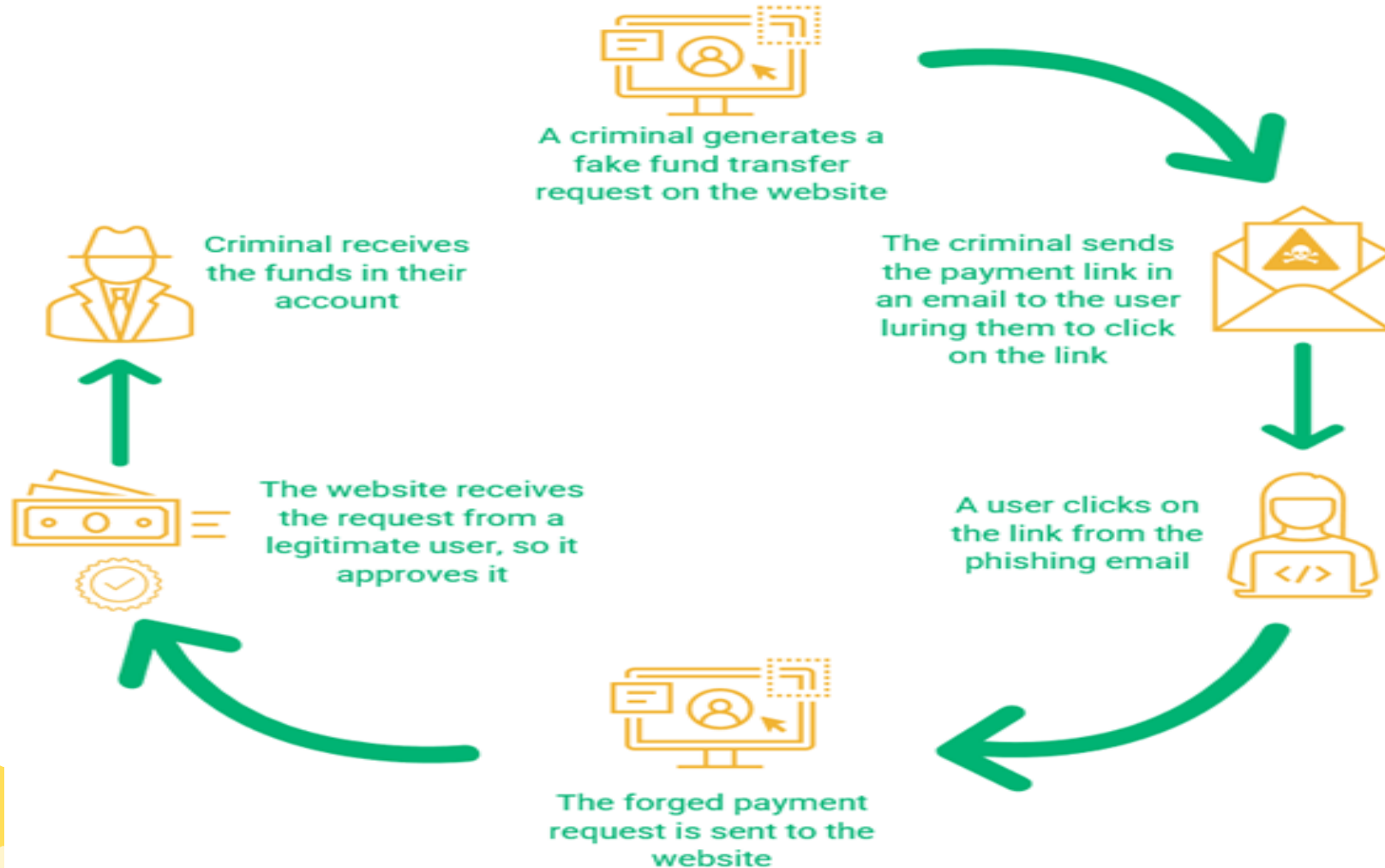
- 3. Cross-Origin Resource Sharing (CORS) Misconfiguration:** Configure CORS policies correctly to control which domains can access your resources. Limit and validate requests from other domains.
- 4. Inadequate Access Control:** Implement robust access control mechanisms and enforce proper authentication and authorization.

Unit 5: Transport and Application Layer Security

TLS & SSL Security

- 5. **Insecure Session Management:** Employ secure session management techniques and protect sessions from attacks like session fixation and session hijacking.
- 6. **Security Misconfigurations:** Regularly audit and update server and application configurations to minimize security flaws.
- 7. **Lack of Input Validation:** Implement strong input validation and sanitation to block malicious input and prevent injection attacks.
- 8. **Inadequate Authentication and Authorization:** Employ strong user authentication and role-based authorization to ensure users have access only to their authorized resources.

Session Fixation Attack

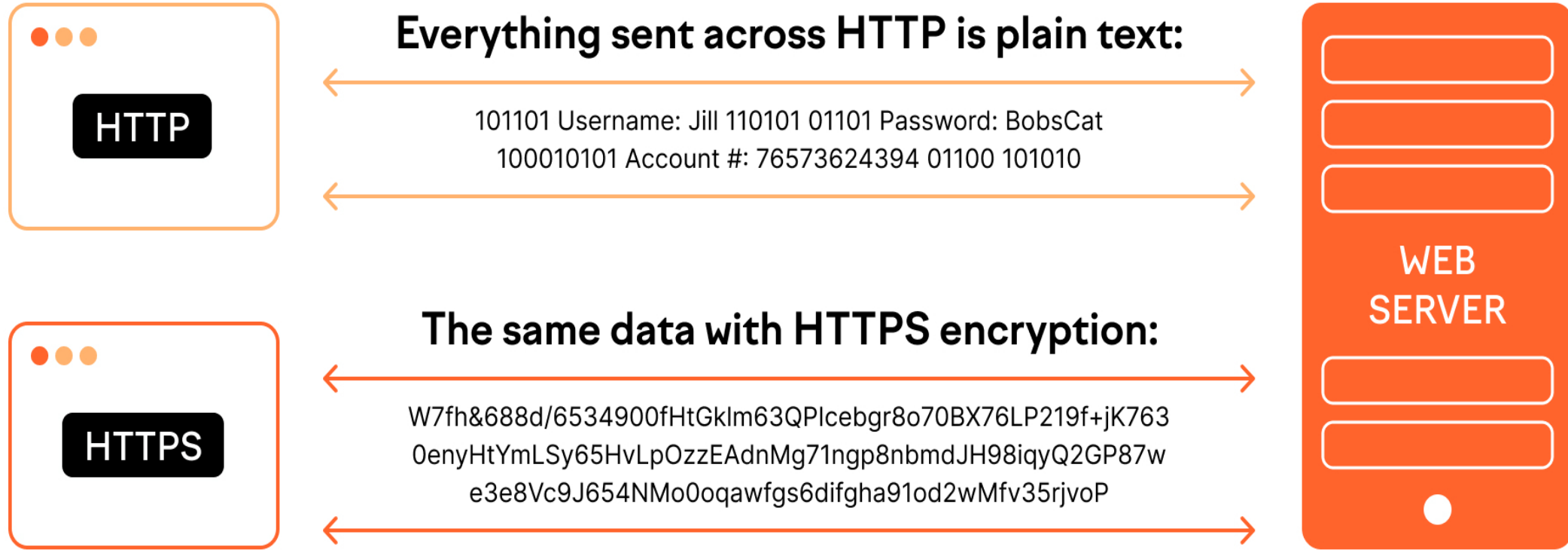


Unit 5: Transport and Application Layer Security

HTTPS

- HTTPS (Hypertext Transfer Protocol Secure) is a combination of the HTTP protocol used for web communication and either SSL (Secure Sockets Layer) or its more secure successor, TLS (Transport Layer Security). Both SSL and TLS are cryptographic protocols used to secure data transmission over the internet.
- It works by combining security mechanisms at both the transport and application layers of the OSI model to provide secure communication over the internet.

Unit 5: Transport and Application Layer Security



Unit 5: Transport and Application Layer Security



Unit 5: Transport and Application Layer Security

HTTPS at Transport Layer Security (TLS)

1. Handshake Phase:

- When a client (e.g., a web browser) initiates an HTTPS connection to a server, the TLS handshake process begins.
- The client sends a "ClientHello" message to the server, indicating its support for various cryptographic algorithms and other security parameters.

Unit 5: Transport and Application Layer Security

HTTPS at Transport Layer Security (TLS)

1. Handshake Phase:

- The server responds with a "ServerHello" message, selecting the best available security settings from the client's list.
- The server also sends its digital certificate to prove its identity. This certificate is signed by a trusted Certificate Authority (CA).

Unit 5: Transport and Application Layer Security

HTTPS at Transport Layer Security (TLS)

2. Key Exchange:

- During the handshake, the client and server negotiate a shared secret key. This key is used for encryption and decryption of data.
- The key exchange can utilize various cryptographic techniques, such as the Diffie-Hellman key exchange, to ensure that even if an eavesdropper intercepts the communication, they cannot determine the shared secret key.

Unit 5: Transport and Application Layer Security

HTTPS at Transport Layer Security (TLS)

3. Data Encryption:

- Once the shared secret key is established, data is encrypted and decrypted using symmetric encryption algorithms, like AES (Advanced Encryption Standard).
- This encryption ensures that the data transmitted between the client and server remains confidential, making it extremely difficult for attackers to read the information.

Unit 5: Transport and Application Layer Security

HTTPS at Transport Layer Security (TLS)

4. Data Integrity and Authentication:

- Hash functions, such as SHA-256, are used to verify the integrity of data. This ensures that data has not been altered during transit.
- The server's digital certificate is used to authenticate the server's identity, assuring the client that it is indeed communicating with the intended and trusted server.

Unit 5: Transport and Application Layer Security

HTTPS at Application Layer Security

1. Browser and Server Interaction:

- The application layer involves the client's web browser and the server software working together to establish a secure connection.
- The web browser plays a significant role in validating the server's certificate and checking for any potential security issues.

Unit 5: Transport and Application Layer Security

HTTPS at Application Layer Security

2. URL Handling:

- The application layer ensures that the URL being accessed is an HTTPS URL, which prompts the browser to establish an encrypted connection.
- It also verifies that the certificate presented by the server matches the domain being accessed.

Unit 5: Transport and Application Layer Security

Secure Shell

Secure Shell (SSH) is a network protocol and application that provides secure communication and remote administration capabilities over unsecured networks. SSH employs both transport layer security and application layer security to establish a secure connection between a client and a server.

Unit 5: Transport and Application Layer Security

Secure Shell

SSH Client

SSH Server

1. Client initiates the connection by contacting server

2. Sends server public key

3. Negotiate parameters and open secure channel

4. User login to server host operating system

Unit 5: Transport and Application Layer Security

Secure Shell at Transport Layer Security (TLS)

1. Handshake Phase:

- SSH uses a cryptographic handshake process similar to that of Transport Layer Security (TLS) but with its own mechanisms.
- When a client wants to establish an SSH connection to a server, the server presents its digital host key to the client.

Unit 5: Transport and Application Layer Security

Secure Shell at Transport Layer Security (TLS)

1. Handshake Phase:

- The client checks the server's key against a list of trusted keys in its `known_hosts` file, ensuring the server's authenticity. If the server's key isn't trusted, the client might prompt the user to verify it manually.
- Once the server's identity is confirmed, the client and server initiate the key exchange process.

Unit 5: Transport and Application Layer Security

Secure Shell at Transport Layer Security (TLS)

2. Key Exchange:

- During the key exchange, SSH establishes a shared secret key between the client and server. This key is used for encryption and data integrity.
- Various encryption algorithms are negotiated during this phase, including symmetric encryption algorithms and key exchange methods.

Unit 5: Transport and Application Layer Security

Secure Shell at Transport Layer Security (TLS)

3. Data Encryption and Integrity:

- After the key exchange, data exchanged between the client and server is encrypted and integrity-protected using the negotiated encryption algorithms.
- This ensures the confidentiality and integrity of data transferred over the SSH connection, making it resistant to eavesdropping and tampering.

Unit 5: Transport and Application Layer Security

Secure Shell at Application Layer Security

1. User Authentication:

- The application layer of SSH involves user authentication. SSH supports various authentication methods, including password-based, public key-based, and multi-factor authentication.
- The user must prove their identity to the server before gaining access. This authentication is an essential security layer, ensuring that only authorized users can access the system.

Unit 5: Transport and Application Layer Security

Secure Shell at Application Layer Security

2. Remote Shell and Command Execution:

- Once the SSH connection is established and the user is authenticated, the client and server can exchange commands and data securely.
- Users can remotely execute shell commands on the server and manage the system as if they were physically present.

Unit 5: Transport and Application Layer Security

Email Security



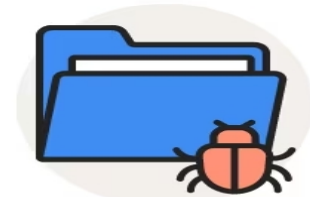
Spear
phishing



Spam
attacks



DDoS
attacks



Malware
attacks



Social engineering
attacks



Email spoofing
attacks



Ransomware
attacks

Unit 5: Transport and Application Layer Security

Email Security

- Email security is crucial to protect the confidentiality and integrity of email messages. Two widely used methods for email security are PGP (Pretty Good Privacy) and S/MIME (Secure/Multipurpose Internet Mail Extensions).
- These protocols use different approaches to achieve similar goals: encrypting and digitally signing email messages.

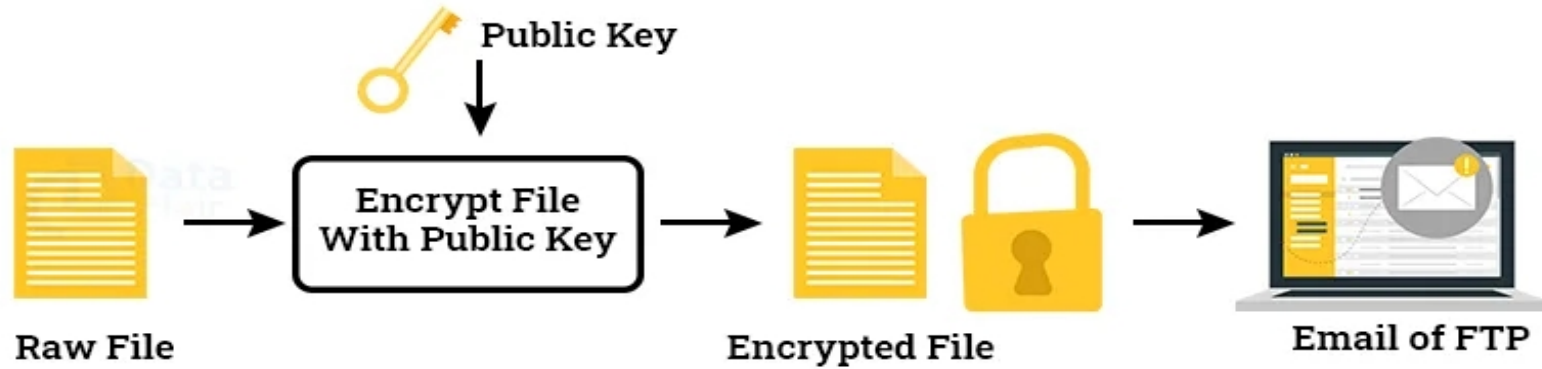
Unit 5: Transport and Application Layer Security

Email Security using PGP (Pretty Good Privacy)

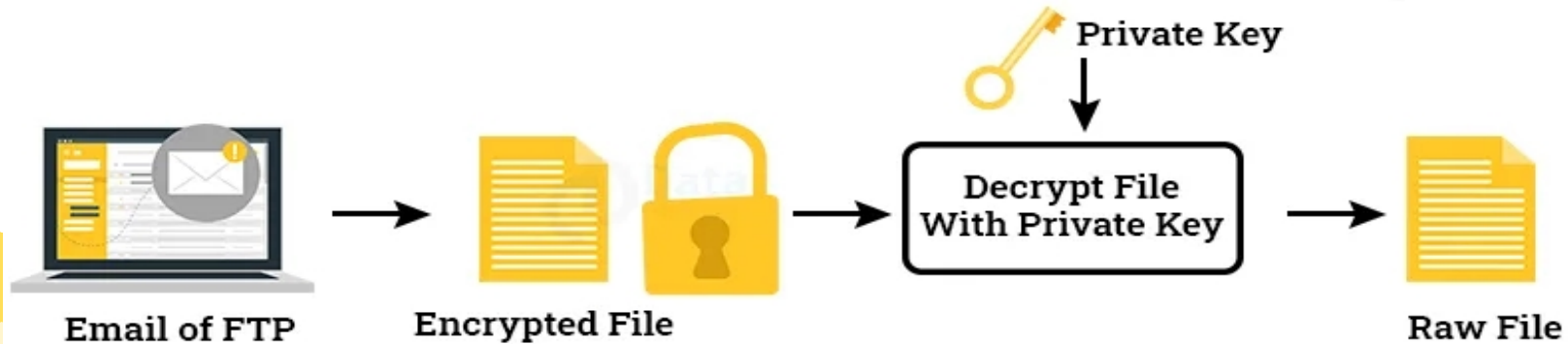
- PGP is a data encryption and decryption program that provides cryptographic privacy and authentication for data communication. It is often used for securing email messages.

PGP (Pretty Good Privacy)

Encryption Process



Decryption Process



Unit 5: Transport and Application Layer Security

Email Security using PGP (Pretty Good Privacy)

1. Key Pair Generation:

- The first step is to generate a PGP key pair for each user. This consists of a public key (used for encryption) and a private key (used for decryption and digital signatures). The public key can be shared with others, while the private key must be kept secret.

Unit 5: Transport and Application Layer Security

Email Security using PGP (Pretty Good Privacy)

2. Encryption:

- When a user wants to send an encrypted email, they use the recipient's public key to encrypt the message. This ensures that only the recipient, who possesses the corresponding private key, can decrypt and read the email.

Unit 5: Transport and Application Layer Security

Email Security using PGP (Pretty Good Privacy)

3. Digital Signatures:

- To digitally sign an email, the sender uses their private key to create a digital signature for the email. This signature is a cryptographic proof of the sender's identity and ensures the integrity of the message.

Unit 5: Transport and Application Layer Security

Email Security using PGP (Pretty Good Privacy)

4. Key Trust and Web of Trust:

- PGP relies on a decentralized web of trust. Users vouch for the authenticity of each other's public keys, which helps build trust in the key pairs. If a user trusts another's public key, they can be more confident in the authenticity of messages signed with that key.

Unit 5: Transport and Application Layer Security

Email Security using PGP (Pretty Good Privacy)

5. Key Servers:

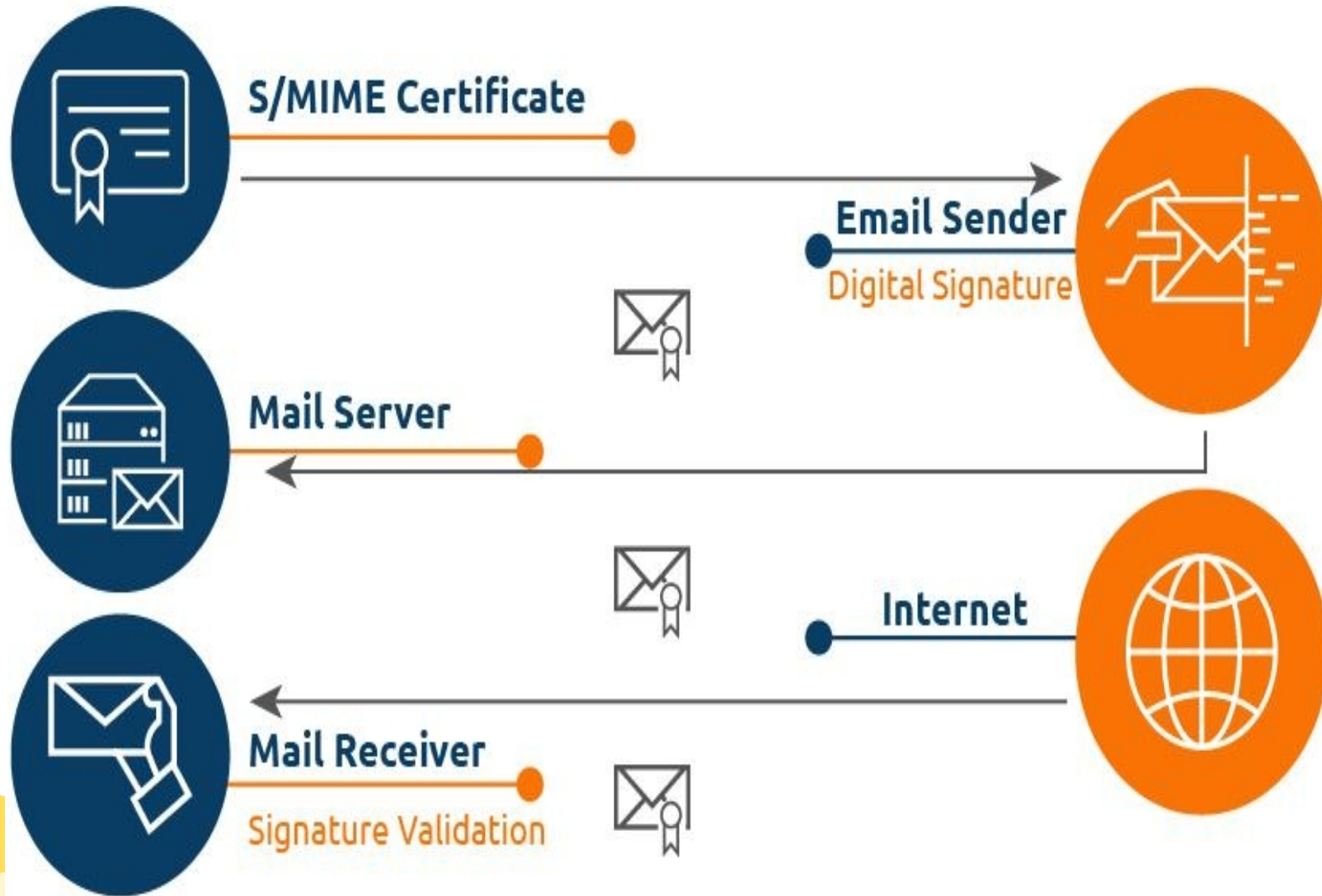
- Public keys are often uploaded to key servers, making it easy for users to find and verify each other's public keys. These keys can be retrieved from key servers when needed.

Unit 5: Transport and Application Layer Security

Email Security using S/MIME (Secure/Multipurpose Internet Mail Extensions)

- S/MIME is a standard for public key cryptography used to secure email messages. It is widely integrated with email clients and uses X.509 digital certificates for encryption and digital signatures.

S/MIME (Secure/Multipurpose Internet Mail Extensions)



Unit 5: Transport and Application Layer Security

Email Security using S/MIME (Secure/Multipurpose Internet Mail Extensions)

1. Digital Certificates:

- To use S/MIME, users must obtain digital certificates from a trusted Certificate Authority (CA). These certificates contain their public keys and are used to verify their identity.

Unit 5: Transport and Application Layer Security

Email Security using S/MIME (Secure/Multipurpose Internet Mail Extensions)

2. Email Encryption:

- When sending an encrypted email, the sender uses the recipient's public key from their certificate to encrypt the email. Only the recipient, with their corresponding private key, can decrypt and read the message.

Unit 5: Transport and Application Layer Security

Email Security using S/MIME (Secure/Multipurpose Internet Mail Extensions)

3. Digital Signatures:

- S/MIME allows the sender to digitally sign an email using their private key. The recipient can verify the signature with the sender's digital certificate, ensuring the message's authenticity and integrity.

Unit 5: Transport and Application Layer Security

Email Security using S/MIME (Secure/Multipurpose Internet Mail Extensions)

4. Trusted CAs:

- S/MIME relies on trusted CAs to issue digital certificates. These CAs have a predefined level of trust in the digital certificate infrastructure, ensuring the authenticity of the keys and the binding between keys and email addresses.

PGP	S/MIME
It is designed for processing the plain texts.	While it is designed to process email as well as many multimedia files.
In PGP Trust is established using Web of Trust.	In S/MIME Trust is established using Public Key Infrastructure.
PGP don't provides authentication.	S/MIME provides authentication.
PGP is less efficient than S/MIME.	While it is more efficient than PGP.
It depends on user key exchange.	Whereas it relies on a hierarchically valid certificate for key exchange.
PGP is comparatively less convenient.	While it is more convenient than PGP due to the secure transformation of all the applications.
PGP is used for Securing text messages only.	S/MIME is used for Securing Messages and attachments.
PGP is the standard for strong encryption.	While it is also the standard for strong encryption but has some drawbacks.
PGP is also be used in VPNs.	While it is not used in VPNs, it is only used in email services.
PGP uses Diffie hellman digital signature.	While it uses Elgamal digital signature.

Unit 5: Transport and Application Layer Security

Email Security

In both PGP and S/MIME, email messages are protected through encryption and digital signatures. PGP uses a decentralized web of trust, and users actively manage their key pairs, while S/MIME relies on trusted Certificate Authorities. The choice between the two often depends on user preferences and the specific email clients and systems in use. Both technologies enhance email security by preventing eavesdropping and ensuring the authenticity of the message and sender.